

물리적보안 지침



주식회사 모인

개정 이력

[illegible]

물리적보안지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사”라 한다)의 정보자산에 대하여 훼손, 위·변조, 도난, 유출 등의 다양한 형태의 침해 위협으로부터 물리적으로 안전하게 보호하기 위하여 필요한 사항을 규정하는 것을 목적으로 한다.

제2조(적용 대상) 이 지침은 회사 내의 물리적 공간과 이를 이용 및 관리하는 임직원, 임시직원 및 외부직원을 포함한 모든 자를 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

- 1 "보호구역"이란 공용구역과 구분하여 비인가자에 대한 접근을 통제할 필요가 있는 구역을 의미한다.
- 2 "집적정보통신시설"이란 정보통신서비스를 제공하는 고객의 위탁을 받아 컴퓨터장치 등 정보시스템 장비를 전산실에 집중하여 관리하는 시설을 의미한다.
- 3 "영상정보처리기기"란 일정한 공간에 지속적으로 설치되어 사람 또는 사물의 영상 등을 촬영하거나 이를 유선 및 무선망을 통하여 전송하는 장치를 의미하며, 폐쇄회로 텔레비전, 네트워크 카메라가 이에 해당된다.
- 4 "개인영상정보"란 영상정보처리기기에 의하여 촬영 및 처리되는 영상정보 중 개인의 초상, 행동 등과 관련된 영상으로서 해당 개인을 식별할 수 있는 정보를 의미한다.
- 5 "전산실"이란 전산장비, 통신 및 보안장비, 전산자료 보관 및 출력장비가 설치된 장소를 의미한다.

제2장 역할 및 책임

제4조 (정보보호 담당자)

- 1 정보보호 담당자는 물리적 보안 정책 수립의 책임을 가진다.
- 2 회사 전체 보호구역에 대한 물리적 보안 통제 적용 및 운영 현황 점검 등 관리적 책임을 가진다.

제5조 (물리보안 담당자)

- 1 물리보안 담당자는 해당 보호구역 내 임직원 및 외부자의 접근권한을 부여하고 관리할 책임을 갖는다.
- 2 보호구역의 안전한 보호와 관리가 이루어질 수 있도록 출입 및 작업의 통제·관리 책임을 갖는다
- 3 해당 보호구역내 장비 등의 반출·입을 관리하고 보호구역내 환경을 상시 점검한다.
- 4 영상정보처리기기를 설치 및 운영하고 영상정보에 대해 안전하게 관리할 책임을 가진다.

제3장 보호구역

제6조(보호구역 설정)

- 1 회사 정보자산의 물리적 보호를 위해 다음 각 호와 같이 물리적 보호구역을 구분한다.
 - 1) 접근 구역은 접근장소 등과 같이 외부인이 별다른 출입증 없이 출입이 가능한 장소를 의미한다.
 - 2) 제한구역은 비인가된 접근을 방지하기 위하여 별도의 출입통제 장치 및 감시시스템이 설치된 장소로 사무실 업무공간 등을 포함한다.
 - 3) 통제구역은 전산센터 및 재해 복구센터, 전산자료 보관실 및 정보보호 시스템 설치장소 등이

해당된다.

2 보호구역별 관리자를 지정하여 보호구역내 출입통제 등 보안 통제를 이행할 수 있도록 하여야 한다.

제7조(제한구역 통제)

- 1 물리보안 담당자는 임직원의 업무상 출입이 필요한 제한구역에 대한 출입권한을 부여하고, 인사변동 및 퇴사 즉시 불필요한 출입 권한을 삭제하여야 한다.
- 2 제한구역은 출입카드, 지문인식기 등 출입통제 장치를 이용하여 비인가자의 출입을 통제하고 기록하여야 한다.
- 3 외부자의 제한구역 출입 시에는 출입 기록을 관리하고, 외부자의 이동 시에는 업무관련 내부직원이 동행하여야 한다.
- 4 내·외부자의 출입기록은 3개월 이상 보존하여야 하며, 정보보호 담당자는 출입기록 및 출입권한을 주기적으로 검토하여야 한다.

제8조(통제구역 통제)

- 1 통제구역의 출입권한은 최소인원에게만 부여하고 정보보호 담당자가 승인한 임직원 및 협력업체 직원으로 한정한다.
- 2 통제구역으로 지정된 장소는 ‘통제구역’이란 표식을 부착하여 주요 장비와 시설이 설치되어 있음을 표시하여야 한다.
- 3 통제구역 내에서의 작업을 24시간 모니터링 할 수 있도록 영상정보처리기를 설치하고 녹화기록을 잠금 장치가 설치된 안전한 장소에 보관하여야 한다
- 4 외부 방문자의 통제구역 내 활동은 다음 각 호에 따라 통제하여야 한다.
 - 1) 통제구역 내 작업 시 해당 업무담당자와 정보보호 담당자의 확인 및 승인
 - 2) 작업일자, 작업시간, 작업목적, 작업내용, 작업업체 및 담당자, 확인자, 승인자 등 작업 관련내용 기록·관리 (3개월 이상 보관)
 - 3) 모바일기기 및 이동식 저장매체의 반입 금지
- 5 정보보호 담당자는 내·외부자의 작업 수행을 위한 통제구역 출입 절차 준수 여부 및 출입기록의 주기적 점검을 수행하고 문제점이 발견된 경우 영상정보처리기기 녹화 기록과 출입관리기록을 비교하여 원인을 분석하여야 한다

제4장 전산실 보호

제9조(건물에 관한 사항) 회사는 전산실이 위치한 건물에 관하여 다음 각 호의 사항을 준수하여야 한다.

- 1 건물 출입구는 경비원에 의하여 통제하고 제8조(통제구역 통제) 요구사항에 준하는 내·외부자 출입통제 대책을 적용하여야 한다.
- 2 비상시 대피를 위하여 전산센터의 각 통로에는 비상구 표시가 있어야 하며 비상계단 및 정전대비 유도등을 설치하여야 한다.
- 3 번개, 과전류 등으로부터 전산장비 및 통신장비 등의 피해 예방을 위하여 피뢰설비를 설치하여야 한다.
- 4 무거운 장비의 하중에 견딜 수 있도록 서버 등 전산장비 및 통신장비 등의 중량을 감안한 적재하중 안전대책을 수립 및 운용하여야 한다.
- 5 화재발생 시 조기진압을 위한 소화기 및 자동소화설비 등을 갖추고, 화재 전파방지를 위한 배연설비설치 등 화재예방 안전대책을 수립 및 운용하여야 한다.
- 6 화재, 진동, 먼지 등 재해로 인하여 전산실 가동에 영향을 미칠 수 있는 장소에는 전산실 구축을 하여서는 아니 된다.

제10조(전원, 공조 등 설비에 관한 사항) 회사는 전산실이 위치한 건물의 전원, 공조 등 설비에 관하여 다음 각 호의 사항을 준수하여야 한다.

- 1 전원, 공조, 방재 및 방범 설비에 대해 상시 감시를 위하여 중앙감시시설, 영상정보처리기기 등 감시제어시스템을 설치하여야 한다.
- 2 전산실의 전력공급 중단에 대비하여 자가발전설비를 갖추어야 한다.
- 3 전산실의 외부 전력공급 중단, 순간 정전에 대비하여 전력선을 이중화하고 무정전전원장치(UPS)를 갖추어야 한다.
- 4 과전압, 누전, 전압변동 등으로 인한 전원 이상을 방지하는 과전류차단기, 누전경보기, 정전압안정주파수(CVCF: Constant Voltage Constant Frequency) 등의 장비를 구비하여야 한다.
- 5 전산실에 안정적인 전원공급을 위하여 전원설비는 전산장비의 부하가 큰 설비부분과 분리하여 운영하고, 공조 설비에 대한 정기적인 상태 점검을 위하여 각종 계측장치를 설치하여 점검을 실시하여야 한다.
- 6 24시간 동안 적절한 온도 및 습도를 유지하기 위해서 자동제어 항온·항습기를 갖추어야 한다.

제11조(전산실 등에 관한 사항) 회사는 전산실에 관하여 다음 각 호의 사항을 준수하여야 한다.

- 1 각 보호구역의 중요도 및 특성에 따라 화재·수해 등의 재해 및 외부 위해(危害) 방지대책을 수립 및 운용하여야 한다.
- 2 상시 출입문은 한 곳으로 정하며 상시 출입은 업무와 직접 관련이 있는 사전 등록자에 한하여 허용하고, 그 밖의 출입자에 대하여는 책임자의 승인을 받아 출입하도록 하며 출입자 관리기록부를 기록 및 보관하여야 한다.
- 3 출입문은 이중 안전장치로 보호하며 외벽이 유리인 경우 유리창문을 통하여 접근할 수 없도록 조치하여야 한다.
- 4 천정, 바닥, 벽 등을 통하여 침수가 발생하는 경우 정보처리시스템의 장애 또는 고장의 원인이 되므로 전산장비는 외벽과 일정한 거리를 두고 설치하고, 바닥을 이중으로 구성하는 등 조치를 취하여야 한다.
- 5 적정수준의 온·습도를 유지하기 위하여 온·습도 자료 자동기록장치 및 경보시스템을 구축하여야 한다.
- 6 케이블이 안전하게 유지되도록 전용 통로관 설치, 식별 표시, 등 적절한 보호조치를 취하여야 하며, 배전반, 약전실 등에는 인가된 최소한의 인력만 접근할 수 있도록 통제하여야 한다.
- 7 정전 시에도 업무 수행 및 대피가 용이하도록 조명설비, 휴대용 손전등을 비치하여야 한다.
- 8 전산실은 국내에 설치하여야 한다.
- 9 무선통신망을 설치하여서는 안 된다.

제12조(집적정보통신시설 이용 시 보안)

- 1 회사는 집적정보통신시설 등과 같이 다수의 기관이 공동으로 이용하는 장소에 정보처리시스템을 설치하는 경우에는 미승인자가 접근하지 못하도록 적절한 접근통제 대책을 마련하여야 한다.
- 2 회사는 외부 집적정보통신시설에 위탁 운영하는 경우 정보보호 관련 법규 준수, 화재, 전력 이상 등 재난·재해 대비, 출입통제 체계, 자산 반출입 통제, 영상감시 등 물리적 보안통제 적용 여부 및 사고 발생 시 손해 배상에 관한 사항 등을 확인하고, 운영 상태를 주기적으로 점검하여야 한다.

제13조(반출·입 관리)

- 1 보호구역 내 정보자산의 반출·입은 보호구역 출입통제 책임자의 사전 승인을 득해야 한다.
- 2 정보자산의 반·출입 내역을 기록하고 이를 유지·관리하여야 한다.
- 3 정보보호 담당자는 정보자산의 반출 시 정보자산 내에 중요정보의 유출이 가능한지 여부를 점검하고, 저장매체 또는 장비 자체에 중요정보가 포함된 경우, 중요정보를 삭제 후 반출하여야 한다.

- 4 정보보호 담당자는 전산장비 반입 시 내부망 연결 필요성을 확인하고, 필요 시 자체 보안성 검토 및 보안조치가 이루어질 수 있도록 관리하여야 한다.
- 5 정보보호 담당자는 보호구역내 정보자산의 반출입 내역을 주기적으로 검토하여 반출입 통제절차의 준수 여부를 확인하여야 한다.

제5장 사무공간 보안관리

제14조(개인업무환경 보안)

- 1 사용자는 일정시간 컴퓨터 미 사용시 화면보호기를 설정하고 일정 기간 이석 시 컴퓨터를 로그오프 하여야 한다.
- 2 사용자는 컴퓨터 재시작 시 로그인 암호를 설정하여야 한다.
- 3 사용자는 안전한 로그인 비밀번호를 사용하고 주기적(90일)으로 변경하여야 한다.
- 4 사용자는 일정시간 자리 이석, 퇴근, 휴가 시 책상 위에 중요문서, 저장매체를 방치해서는 안 된다.
- 5 사용자는 중요 문서는 시건장치가 설치된 서랍장, 캐비닛 등을 사용하여 보관하여야 한다.
- 6 사용자는 로그인 정보(ID, 비밀번호)에 대해 메모지 등에 기록해서는 안 된다.
- 7 사용자는 중요 정보가 포함된 문서 폐기 시에는 파쇄기를 이용하여 복구할 수 없도록 파쇄하여야 한다.
- 8 정보보안팀(이하 “보안팀”)은 불시에 사용자들이 개인업무환경에서의 정보보안 활동을 준수하고 있는지에 대해 점검을 수행할 수 있으며, 미흡사항에 대해 개선을 요구할 수 있다.

제15조(공용업무 환경 보안)

- 1 사용자는 공용사무기기(팩스, 복사기, 프린트 등) 주변에 중요 정보가 포함된 문서를 방치하여서는 안 된다.
- 2 보안팀은 공용 PC의 경우 관리 담당자를 지정하고, 화면보호기 설정, 로그인 암호설정, 주기적으로 패스워드 변경, 중요정보 저장 제한, 백신 설치 및 보안 업데이트를 실시하도록 한다.
- 3 보안팀은 업무상 파일서버 등 사용시 접근권한을 부서 및 업무 등 필요에 의한 최소 권한을 부여하여 불필요한 정보 공개를 최소화하고, 사용자 별 별도 접근 계정을 발급하여야 한다.
- 4 보안팀은 회의실, 프로젝트 룸 등의 공용 사무실에 중요정보가 포함된 문서 등이 방치되지 않도록 관리하여야 한다.
- 5 보안팀은 불시에 공용업무 환경에서의 물리적인 정보보안 활동이 준수되고 있는지에 대해 점검할 수 있으며, 미흡사항에 대해 개선을 요구할 수 있다.

제6장 영상정보처리기기 설치 및 운영 관리

제16조(영상정보처리기기 설치)

- 1 회사는 영상정보처리기기 설치 시 다음 각 호에 해당되는 경우에만 영상정보처리기기를 설치 및 운영하여야 한다.
 - 1) 법령에서 구체적으로 허용하고 있는 경우
 - 2) 범죄의 예방 및 수사를 위하여 필요한 경우
 - 3) 시설안전 및 화재 예방을 위하여 필요한 경우
- 2 회사는 불특정 다수가 이용하는 화장실 등 개인의 사생활을 현저히 침해할 우려가 있는 장소의 내부를 볼 수 있도록 영상정보처리기기를 설치 및 운영하여서는 아니 된다.
- 3 회사는 영상정보처리기기의 설치 목적 변경에 따른 추가 설치 등의 경우에도 관계 전문가 및 이해관계인의 의견을 수렴하여야 한다.

제17조(영상정보처리기기 운영)

- 1 물리보안 담당자는 다음 각 호의 사항이 포함된 영상정보처리기기 운영 및 관리 방침을 마련하여야 한다.
 - 1) 영상정보처리기기의 설치 근거 및 설치 목적
 - 2) 영상정보처리기기의 설치 대수, 설치 위치 및 촬영 범위
 - 3) 관리책임자, 담당 부서 및 영상정보에 대한 접근 권한이 있는 사람
 - 4) 영상정보의 촬영시간, 보관기간, 보관장소 및 처리방법
 - 5) 영상정보처리기기운영자의 영상정보 확인 방법 및 장소
 - 6) 정보주체의 영상정보 열람 등 요구에 대한 조치
 - 7) 영상정보 보호를 위한 기술적·관리적 및 물리적 조치
 - 8) 그 밖에 영상정보처리기기의 설치·운영 및 관리에 필요한 사항
- 2 영상정보처리기기에 의하여 화상정보를 수집하는 경우에는 그 설치목적을 넘어 카메라를 임의로 조작하거나 다른 곳을 비추어서는 아니된다.
- 3 영상정보처리기기에 의하여 화상정보를 수집하는 경우에는 녹음 기능을 사용하지 아니한다.

제18조(안내판 설치)

- 1 회사는 영상정보처리기기를 설치할 경우 정보주체가 쉽게 인식할 수 있도록 다음 각 호의 사항을 기재한 안내판을 설치하는 등 필요한 조치를 취하여야 한다.
 - 1) 설치 목적 및 장소
 - 2) 촬영 범위 및 시간
 - 3) 관리책임자 성명 및 연락처
 - 4) 위탁 받은 자의 명칭 및 연락처(영상정보처리기기 설치·운영 사무 위탁 시)
 - 5) 그 밖에 정보보호최고책임자가 정하는 사항
- 2 제1항에 따른 안내판은 촬영범위 내에서 정보주체가 알아보기 쉬운 장소에 누구라도 용이하게 관독할 수 있게 설치한다.
- 3 제2항에도 불구하고 회사의 건물 안에 다수의 영상정보처리기기를 설치하는 경우에는 출입구 등 잘 보이는 곳에 해당 시설 또는 장소 전체가 영상정보처리기기 설치지역임을 표시하는 안내판을 설치할 수 있다.

제19조(개인 영상정보 이용 및 제3자 제공 등 제한) 물리보안 담당자는 다음 각 호를 제외하고는 개인영상정보를 수집 목적 이외로 이용하거나 제3자에게 제공하여서는 아니 된다.

- 1 정보주체에게 동의를 얻은 경우
- 2 다른 법률에 특별한 규정이 있는 경우
- 3 정보주체 또는 그 법정대리인이 의사표시를 할 수 없는 상태에 있거나 주소불명 등으로 사전동의를 받을 수 없는 경우로서 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우
- 4 통계 작성 및 학술 연구 등을 목적을 위하여 필요한 경우로서 특정 개인을 알아볼 수 없는 형태로 개인영상정보를 제공하는 경우
- 5 개인영상정보를 목적 외의 용도로 이용하거나 이를 제3자에게 제공하지 아니하면 다른 법률에서 정하는 소관업무를 수행할 수 없는 경우로서 정보보호위원회의 심의·의결을 거친 경우

제20조(개인영상정보의 안전성 확보 조치) 물리보안 담당자는 개인영상정보가 분실, 도난, 유출, 변조 또는 훼손되지 아니하도록 안전성 확보를 위해 다음 각 호의 조치를 취해야 한다.

- 1 개인영상정보에 대한 접근 통제 및 접근 권한의 제한 조치
- 2 개인영상정보를 안전하게 저장 및 전송할 수 있는 기술의 적용

- 3 처리기록의 보관 및 위조, 변조 방지를 위한 조치
- 4 개인영상정보의 안전한 물리적 보관을 위한 보관시설 마련 또는 잠금 장치 설치

제21조(영상정보의 보관 및 삭제)

- 1 물리보안 담당자는 영상정보의 보관 기간을 정하여 보관 기간 만료 시 지체 없이 파기하여야 한다. 다만, 보유목적의 달성을 위한 최소한의 기간 산정이 어려운 경우는 보관 기간을 개인영상정보 수집 후 30일 이내로 한다.
- 2 개인영상정보의 파기 방법은 다음 각 호의 어느 하나와 같다.
 - 1) 개인영상정보가 기록된 출력물 등은 파쇄 또는 소각
 - 2) 전자기적 파일 형태의 개인영상정보는 복원이 불가능한 기술적 방법으로 영구 삭제
 - 3) 전산실 출입을 모니터링 하는 IDC 내 영상정보처리기는 최소 3개월간의 영상기록을 보존해야 하며, 영상기록이 변조되지 않도록 해야 한다

제22조(이용, 제3자제공, 파기 기록 및 관리)

- 1 물리보안 담당자는 개인영상정보를 수집목적 이외로 이용하거나 제3자에게 제공하는 경우에는 다음 각호의 사항을 기록하고 관리하여야 한다.
 - 1) 개인영상정보 파일의 명칭
 - 2) 이용하거나 제공받은 자의 명칭
 - 3) 이용 또는 제공의 목적
 - 4) 법령상 이용 또는 제공근거가 있는 경우 그 근거
 - 5) 이용 또는 제공의 기간이 정해져 있는 경우에는 그 기간
 - 6) 이용 또는 제공의 형태
- 2 개인영상정보를 파기하는 경우에는 다음 각 호의 내용을 기록하고 관리하여야 한다.
 - 1) 파기하는 개인영상정보 파일의 명칭
 - 2) 개인영상정보 파기 일시
 - 3) 개인영상정보 파기 담당자

제23조(영상정보처리기기 설치 및 관리의 위탁)

- 1 물리보안 담당자는 영상정보처리기기의 설치 및 관리에 관한 사무를 위탁하려는 경우 다음 각호의 내용을 위탁계약서에 등 관련 서류에 분명하게 기록한다.
 - 1) 위탁하는 사무의 목적 및 범위
 - 2) 재위탁 제한에 관한 사항
 - 3) 영상정보에 대한 접근 제한 등 안전성 확보 조치에 관한 사항
 - 4) 영상정보의 관리 현황 점검에 관한 사항
 - 5) 위탁 받는 자가 준수하여야 할 의무를 위반한 경우의 손해배상 등 책임에 관한 사항
- 2 제1항에 따라 사무를 위탁한 경우에는 안내판에 수탁업체의 명칭, 담당자 및 연락처를 게재한다.

부칙

- 제1조(시행일)** 이 지침의 시행일은 대표이사가 승인한 날로 한다.